

INFORME DE PENTESTING

Lautaro Fiochetta

Índice

Índice	2
Datos Generales	3
Pre-Pentesting	3
Alcance del trabajo	3
Reglas de Enfrentamiento (ROE)	3
Autorización	3
Metodología utilizada	3
Entorno de trabajo	4
Hallazgos por Máquina	4
Máquina: Basic Pentesting (Linux)	4
Hallazgo H-01 — Recurso SMB accesible de forma anónima	4
Hallazgo H-02 — Contraseña SSH débil (fuerza bruta)	4
Hallazgo H-03 — Clave privada SSH con permisos inseguros y escalada a root	5
Máquina: Blue (Windows) — Sala de Nivel 2	5
Hallazgo H-04 — EternalBlue (MS17-010): ejecución remota de código en SMBv1	5
Resumen Ejecutivo de Hallazgos	6
Recomendaciones	6
Recomendaciones técnicas (priorizadas por criticidad)	6
Recomendaciones administrativas	6
Protocolo de Contingencia	7
Escenario de falla	7
Impacto sobre la continuidad del negocio	7
Plan de respuesta	7
RTO y RPO estimados	7
Anexos	7
Anexo A — Bitácoras de comandos	7
Anexo B — Capturas de pantalla	7
Anexo C — Hashes de las flags obtenidas (SHA-256)	7
Anexo D — Declaración ética	8
Fuentes y bibliografía	9

Datos Generales

Cliente	INSECUR S.A.
Contratista (alumno)	Lautaro Fiochetta
DNI	44 309 650
Username TryHackMe	fiochettalautaro02
Email institucional	fiochettalautaro@uch.edu.ar
Núcleo obligatorio	Pentesting Fundamentals, Basic Pentesting
Sala de elección (Nivel 2)	Blue (Windows / EternalBlue)
Branch en GitHub	fiochetta-lautaro
Fecha de inicio	04/10/2026
Fecha de cierre	08/10/2026

Pre-Pentesting

Alcance del trabajo

El alcance se limita exclusivamente a los entornos de laboratorio autorizados de la plataforma TryHackMe asignados en la guía de la actividad. Las máquinas evaluadas fueron las correspondientes a las salas Basic Pentesting (Linux), Blue (Windows) y OWASP Juice Shop (aplicación web). Queda expresamente excluido cualquier sistema real o de producción; no se aplicó ninguna técnica fuera de los entornos controlados mencionados.

Reglas de Enfrentamiento (ROE)

- Las pruebas se realizaron únicamente sobre las direcciones IP asignadas dinámicamente por TryHackMe a cada máquina objetivo.
- No se ejecutaron acciones destructivas: pese a haber obtenido control total de las máquinas, las actividades se limitaron a documentar el acceso y recuperar la evidencia (flags).
- No se realizó ningún movimiento hacia sistemas fuera del alcance definido.
- Toda la conexión se realizó a través de la VPN oficial de TryHackMe (OpenVPN).

Autorización

Se declara que se cuenta con autorización expresa de la cátedra para desarrollar las actividades de hacking ético sobre los entornos de laboratorio de TryHackMe indicados en la guía de la Actividad A08. La actividad se enmarca en un contexto académico y controlado.

Metodología utilizada

Se adoptó el marco PTES (Penetration Testing Execution Standard), por tratarse de un estándar ampliamente reconocido que estructura el proceso en fases claras: reconocimiento, escaneo, enumeración, explotación, post-explotación y reporte. Esta estructura permite documentar ordenadamente cada hallazgo y es directamente aplicable a los entornos trabajados. Como referencia complementaria para la evaluación técnica se consideró la guía NIST SP 800-115.

Entorno de trabajo

Se utilizó Kali Linux sobre WSL2 (Windows Subsystem for Linux) como plataforma de ataque, con las herramientas nmap, hydra, John the Ripper, smbclient y Metasploit Framework. La conexión a los laboratorios se realizó mediante el cliente OpenVPN con el archivo de configuración personal de TryHackMe.

Hallazgos por Máquina

A continuación se detallan los hallazgos de cada máquina evaluada. Por tratarse de un entorno de laboratorio, las credenciales se presentan parcialmente redactadas siguiendo buenas prácticas de reporting profesional; en un entorno productivo real se omitirían por completo o se entregarían por un canal seguro separado.

Máquina: Basic Pentesting (Linux)

Sistema Linux (Ubuntu) con múltiples servicios expuestos (SSH, Apache, Samba, Tomcat). El compromiso se logró mediante la enumeración de un recurso SMB anónimo, fuerza bruta de SSH y una escalada de privilegios por mala configuración de permisos, llegando hasta el usuario root.

Hallazgo H-01 — Recurso SMB accesible de forma anónima

Fase	Reconocimiento / Enumeración
Descripción	El servicio Samba (puertos 139/445) exponía un recurso compartido llamado 'Anonymous' accesible sin autenticación, que contenía un archivo (staff.txt) con nombres de usuarios del sistema (jan, kay).
Componente afectado	Servicio Samba (SMB)
Categoría	CWE-284 — Control de acceso incorrecto
Herramienta	nmap, smbclient
Impacto (Tríada CIA)	Confidencialidad
Severidad estimada	Media
Salvaguarda propuesta	Deshabilitar el acceso anónimo a los recursos Samba; exigir autenticación y aplicar el principio de mínimo privilegio.
Riesgo residual	Bajo

Hallazgo H-02 — Contraseña SSH débil (fuerza bruta)

Fase	Explotación
Descripción	El usuario 'jan' poseía una contraseña débil presente en diccionarios públicos (rockyou), lo que permitió el acceso por SSH mediante un ataque de fuerza bruta (jan : arm•••••).
Componente afectado	Servicio SSH (puerto 22)
Categoría	CWE-521 — Requisitos de contraseña débiles
Herramienta	hydra

Impacto (Tríada CIA)	Confidencialidad, Integridad
Severidad estimada	Alta
Salvaguarda propuesta	Política de contraseñas robustas, bloqueo tras intentos fallidos (fail2ban) y autenticación por clave en lugar de contraseña.
Riesgo residual	Bajo

Hallazgo H-03 — Clave privada SSH con permisos inseguros y escalada a root

Fase	Post-explotación / Escalada de privilegios
Descripción	La clave privada SSH del usuario 'kay' era legible por otros usuarios. Tras crackear su passphrase (bee****) con John the Ripper, se accedió como 'kay', cuyo archivo de respaldo de contraseña (pass.bak) también era legible. El usuario 'kay' tenía permisos sudo totales (ALL:ALL) ALL, lo que permitió escalar directamente a root.
Componente afectado	Permisos de archivos / configuración sudo
Categoría	CWE-732 — Asignación de permisos incorrecta a recurso crítico
Herramienta	John the Ripper, ssh, sudo
Impacto (Tríada CIA)	Confidencialidad, Integridad, Disponibilidad
Severidad estimada	Crítica
Salvaguarda propuesta	Permisos restrictivos (600) en claves privadas; passphrases robustas; revisión y limitación de los privilegios sudo concedidos.
Riesgo residual	Bajo

Máquina: Blue (Windows) — Sala de Nivel 2

Servidor Windows Server 2012 R2 vulnerable a EternalBlue, el fallo de SMBv1 explotado mundialmente por el ransomware WannaCry en 2017.

Hallazgo H-04 — EternalBlue (MS17-010): ejecución remota de código en SMBv1

Fase	Escaneo / Explotación / Post-explotación
Descripción	El servicio SMBv1 (puerto 445) era vulnerable a MS17-010. Mediante Metasploit se obtuvo ejecución remota de código con privilegios NT AUTHORITY\SYSTEM (máximo nivel en Windows), sin necesidad de escalada posterior. Se recuperaron las tres flags de la máquina.
Componente afectado	Servicio SMBv1 (puerto 445)
Categoría	CWE-20 — Validación de entrada incorrecta (desbordamiento en SMBv1)
CVE	CVE-2017-0143 (MS17-010)
Herramienta	nmap (script smb-vuln-ms17-010), Metasploit Framework

Impacto (Tríada CIA)	Confidencialidad, Integridad, Disponibilidad
Severidad estimada	Crítica
Salvaguarda propuesta	Aplicar el parche MS17-010; deshabilitar SMBv1; segmentar la red y restringir el puerto 445 mediante firewall.
Riesgo residual	Bajo

Resumen Ejecutivo de Hallazgos

Severidad	Cantidad	ID de hallazgos
Crítico	3	H-03, H-04, H-05
Alto	1	H-02,
Medio	1	H-01,
Bajo	0	—
Total	5	

Nota: las severidades son estimaciones cualitativas en el contexto académico del laboratorio.

Recomendaciones

Recomendaciones técnicas (priorizadas por criticidad)

- Crítico — Aplicar el parche MS17-010 y deshabilitar SMBv1 en todos los sistemas Windows.
- Crítico — Corregir los permisos de las claves privadas (chmod 600) y revisar los privilegios sudo concedidos a cada usuario.
- Crítico — Implementar consultas parametrizadas en todos los formularios para prevenir la inyección SQL.
- Alto — Reforzar la política de contraseñas y habilitar el bloqueo tras intentos fallidos (fail2ban).
- Alto — Validar la autorización en el servidor para cada recurso (control de acceso basado en roles).
- Alto — Sanear y codificar las salidas e implementar una política de seguridad de contenido (CSP) contra XSS.
- Medio — Deshabilitar el acceso anónimo a los recursos compartidos y a los directorios públicos sensibles.

Recomendaciones administrativas

- Establecer un programa periódico de gestión de parches y actualizaciones.
- Capacitar al personal técnico en configuración segura de servicios.
- Realizar auditorías de seguridad y pruebas de penetración de forma periódica.
- Definir una política formal de contraseñas y de gestión de accesos.

Protocolo de Contingencia

Escenario de falla

El procedimiento de mayor riesgo es la explotación de EternalBlue (H-04): el exploit opera sobre el kernel a través de SMBv1 y, en un entorno de producción, un intento fallido podría provocar un pantallazo azul (BSOD) y la caída del servidor afectado.

Impacto sobre la continuidad del negocio

La caída de un servidor Windows que preste servicios críticos (archivos, autenticación de dominio) interrumpiría las operaciones dependientes durante el tiempo de recuperación, afectando la disponibilidad de la información y los procesos asociados de INSECUR S.A.

Plan de respuesta

- Activación: el monitoreo de disponibilidad de servicios detecta la caída (alertas de red / pérdida de ping).
- Contención (primeros 15 minutos): aislar el servidor afectado de la red para evitar propagación.
- Recuperación: restaurar desde backup o conmutar a un servidor espejo; reiniciar el servicio afectado.
- Comunicación: notificar a la dirección de IT y, si corresponde, a los usuarios afectados.
- Post-mortem: documentar el incidente, la causa raíz y las medidas correctivas aplicadas.

RTO y RPO estimados

RTO (Recovery Time Objective): 4 horas. RPO (Recovery Point Objective): 24 horas (último backup diario).

Anexos

Anexo A — Bitácoras de comandos

Se adjuntan en la carpeta bitacora/ del repositorio las bitácoras detalladas de cada máquina: basic_pentesting_bitacora.txt y blue_bitacora.txt.

Anexo B — Capturas de pantalla

Se adjuntan en la carpeta evidencias/ del repositorio, organizadas por fase (reconocimiento, escaneo, explotacion, post) y por máquina. Las credenciales sensibles aparecen parcialmente redactadas.

Anexo C — Hashes de las flags obtenidas (SHA-256)

Las flags se presentan como hash SHA-256 para su verificación sin exposición directa. Para generar cada hash: `echo -n "<flag>" | sha256sum`

Flag	SHA-256
Basic Pentesting — root	[completar: <code>echo -n "<flag root>" sha256sum</code>]
Blue — flag1	[completar: <code>echo -n "flag{access_the_machine}" sha256sum</code>]
Blue — flag2	[completar: <code>echo -n "flag{sam_database_elevated_access}" sha256sum</code>]

Blue — flag3	[completar: echo -n "flag{admin_documents_can_be_valuable}" sha256sum]
--------------	--

Anexo D — Declaración ética

Declaro que todas las actividades descritas en este informe se realizaron dentro del alcance autorizado, en los entornos controlados de TryHackMe y con fines exclusivamente académicos. Pese a haber obtenido control total de las máquinas evaluadas, no se causó daño alguno a los sistemas ni se accedió a información fuera del alcance definido.

Los hash son:

Blue — flag1 → d993d772601d8863beb7a721df19d7d372447e2b11e085334418252cf8f9abb3
Blue — flag2 → a9ce99cec8c124b6a1f2e8488b4c9212aba6ad902c45177513d17d345e49a849
Blue — flag3 → 5d78372a8b652a1d1fc20ad848e12b6efab324ae5e627c9a4c25984c38df039e

Fuentes y bibliografía

Microsoft. (2017). *Microsoft security bulletin MS17-010: Critical*. Microsoft Security Response Center.

TryHackMe. Pentesting Fundamentals, Basic Pentesting, Blue, OWASP Juice Shop — salas oficiales (tryhackme.com).

National Institute of Standards and Technology. (2008). *Technical guide to information security testing and assessment* (Special Publication 800-115). U.S. Department of Commerce.

OWASP Foundation. (s. f.). *OWASP Top 10*.

OWASP Foundation. (s. f.). *Web Security Testing Guide (WSTG)*.

Penetration Testing Execution Standard. (s. f.). *The penetration testing execution standard*.